



NIST AI RMF vs NIST AI 800-1 compliance audit: map dual-use foundation model controls into Govern, Map, Measure, Manage functions

Computer

Audit-ready AI governance matrix: map NIST AI 800-1 dual-use controls across the four RMF functions with required artifact checkpoints

Computer

Show me how to map the NIST AI RMF functions

Draft the NIST AI 800-1 misuse risk checklist

Integrate model evaluation into the govern function

NIST AI RMF should be Semester’s top-level operating model—**Govern, Map, Measure, Manage**—while NIST AI 800-1 adds a misuse-risk lens for dual-use foundation models. The practical result is one audit-ready governance system rather than separate AI, security, product, and compliance processes.

Status caveat: NIST AI 800-1 has been published by NIST as draft guidance, so it should be treated as a voluntary control source and not represented as a certification or finalized regulatory requirement unless its publication status changes. ^[1586][1597]

RMF function mapping

NIST AI RMF function	Semester purpose	Key question	Operating result
Govern	Establish accountability, policies, oversight, and evidence	Who owns this AI system, and what risk is acceptable?	A controlled AI lifecycle with clear decision rights
Map	Define context, affected people, data, dependencies, and harm scenarios	What can go wrong, for whom, and through which pathway?	Use-case-specific risk register and boundary design
Measure	Test performance, safety, privacy, accessibility, and misuse resilience	How do we know whether controls work?	Evidence-based release and monitoring decisions
Manage	Prioritize, treat, monitor, communicate, and retire risks	What do we do about unacceptable or changing risk?	Documented mitigation, incident response, and continuous improvement

Lifecycle relationship

GOVERN

Sets the accountable owner, policy, risk appetite, required evidence, approval gates, and organizational capability.

MAP

Defines the system, intended use, affected people, data, dependencies, misuse paths, and unacceptable outcomes.

MEASURE

Tests the system against the mapped risks and measures whether safeguards, quality, accessibility, privacy, and misuse controls work.

MANAGE

Accepts, reduces, transfers, monitors, communicates, or stops risk—then feeds the results into the next governance and mapping cycle.

This is a loop, not a linear checklist:

Govern

- Map
 - Measure
 - Manage
 - update Governance, policies, inventory, evaluations, and launch gates

Audit-ready control matrix

Function	AI 800-1 dual-use emphasis	Semester control	Required artifact	Audit checkpoint
Govern	Accountability for misuse risk	Assign executive AI-risk owner and system owner per feature/model	AI governance charter; RACI	Owner and escalation path approved
Govern	Capability and access governance	Risk-tier each model, tool, API, modality, and agent	Model/system inventory	Inventory is current and reviewed quarterly
Govern	Supplier risk	Assess provider retention, training, safety, security, residency, incident notice, and model change terms	AI vendor assessment	No production use without approval
Govern	Misuse policy	Define prohibited uses, tool permissions, user restrictions, and enforcement	Acceptable-use policy; tenant policy config	Policy is visible and enforceable
Govern	Evaluation accountability	Approve evaluation standards, launch thresholds, re-test triggers, and independent review	Evaluation policy; evaluation plan	Feature cannot launch without evidence
Map	Threat context	Identify users, affected parties, use context, high-risk groups, and institutional authority boundaries	Use-case dossier	Context reviewed before build

Function	AI 800-1 dual-use emphasis	Semester control	Required artifact	Audit checkpoint
Map	Misuse pathways	Model deliberate misuse: jailbreaks, prompt injection, exfiltration, fraud, malware, impersonation, dangerous instructions, abuse of tools	AI misuse threat model	Risks have likelihood, impact, owner, mitigation
Map	Tool and agent risk	Identify every external action, system permission, data source, and write operation	Tool-permission map	No unapproved write/action path
Map	Data risk	Classify prompts, sources, files, retrieval data, outputs, logs, and evaluation datasets	AI data-flow diagram	Restricted data prohibited or controlled
Map	Impact assessment	Identify student, staff, institutional, accessibility, privacy, academic-integrity, and reputational harms	AI impact assessment	Unacceptable harms create launch block
Measure	Capability testing	Test what the selected model can generate or execute, including code, multimodal output, and tool use	Capability assessment	Risk tier matches demonstrated capability
Measure	Misuse testing	Red-team for jailbreaks, prompt injection, dangerous content, data exfiltration, fraud, impersonation, and tool misuse	Red-team report	High-severity failures remediated before launch
Measure	Quality and grounding	Measure source fidelity, citation accuracy, hallucination rate, refusal behavior, and policy adherence	Evaluation dataset/results	Meets use-case thresholds
Measure	Privacy/security	Test access control, tenant isolation, leakage, secret exposure, file handling, and provider-boundary controls	Security/privacy test report	No unresolved critical finding
Measure	Accessibility and fairness	Test screen-reader output, reading level, alternative formats, disparate error/refusal patterns, and accommodation impact	Accessibility/fairness test report	Critical barriers fixed or feature blocked
Manage	Control treatment	Apply gating, filters, rate limits, least privilege, sandboxing, confirmation, redaction, and feature flags	Mitigation plan; configuration record	Controls active in production
Manage	Incident response	Detect, triage, contain, communicate, and learn from misuse/safety incidents	AI incident runbook; incident log	Drill performed and lessons tracked
Manage	Access response	Reduce or suspend access where abuse or risk threshold is met	Enforcement/exception procedure	Actions are proportionate and appealable
Manage	Change management	Re-evaluate on model, provider, prompt, policy, integration, modality, or tool change	Change request; re-approval evidence	No material change bypasses review

Function	AI 800-1 dual-use emphasis	Semester control	Required artifact	Audit checkpoint
Manage	Transparency	Give users source/policy/limitation labels and issue-report route	UI evidence; transparency page	User understanding tested
Manage	Retirement	Disable/revoke models, delete or preserve records appropriately, migrate safely, notify tenants	Retirement plan	Exit/recovery drill completed

Govern: integrate model evaluation

Model evaluation belongs in **Govern**, not only in Measure, because leadership must decide in advance what “good enough” means, which harms are unacceptable, who can approve exceptions, and what evidence must exist before launch.

Governance controls for evaluation

- [] Maintain an AI Evaluation Policy approved by the AI Governance Council.
- [] Define risk tiers for every AI use case, model, modality, data class, tool integration, and user population.
- [] Define the required evaluation categories for each risk tier.
- [] Establish release-blocking thresholds before model selection or development.
- [] Define who designs tests, who executes them, and who independently reviews them.
- [] Require test datasets that are synthetic, public, licensed, or otherwise approved.
- [] Prohibit the use of production student records in evaluation unless explicitly authorized, minimized, and subject to documented review.
- [] Set re-evaluation triggers: model version change, provider change, new tool/action, new modality, policy change, incident, material complaint, new data source, or expansion to a new tenant/use case.
- [] Define evidence-retention periods, sign-off requirements, and audit access.
- [] Create a formal risk-acceptance process for residual risk; no informal exceptions.
- [] Require human review and student/institutional representative input for high-impact or sensitive workflows.
- [] Require independent security/privacy/accessibility review for high-risk releases.

Evaluation policy by risk tier

Tier	Example	Evaluation requirement	Launch authority
Tier 0	Non-sensitive internal drafting with no external actions	Basic quality/security review	Product + engineering owner
Tier 1	Student study support using public or student-provided non-sensitive material	Grounding, policy adherence, privacy, accessibility, misuse baseline	Product, AI owner, privacy/security approval
Tier 2	Institution-approved course/material retrieval, career support, or resource navigation	Full quality, source fidelity, tenant isolation, injection, accessibility, bias, abuse, and human-handoff tests	AI governance review

Tier	Example	Evaluation requirement	Launch authority
Tier 3	Tool-enabled workflows, advisor/staff support, sensitive support routing, or broad external API action	Enhanced adversarial testing, permission simulation, incident drill, legal/privacy/accessibility approval, staged rollout	Governance council/executive delegate
Tier 4	High-impact decisions or prohibited domains: admissions, aid, discipline, accommodation, health/crisis diagnosis, hidden student-risk scoring	Do not deploy for automated decision-making	Prohibited unless redesigned into non-decision support

NIST AI 800-1 misuse-risk checklist

AI 800-1 is aimed most directly at developers of dual-use foundation models. Semester should apply the parts relevant to a SaaS deployer: provider governance, capability assessment, misuse threat modeling, access control, monitoring, incident response, and transparency. NIST's draft describes voluntary best practices for developers managing misuse risk from dual-use foundation models. [^1588]

1. Applicability and inventory

- [] Identify whether Semester develops, fine-tunes, hosts, or accesses each model.
- [] Record provider, model/version, modality, deployment region, API/tool access, tenant availability, and business owner.
- [] Record user groups: student, faculty, staff, administrator, partner, public.
- [] Record data types processed: public, institution-approved, student-provided, education-record PII, sensitive/restricted, or prohibited.
- [] Record external integrations, agentic capabilities, and write permissions.
- [] Assign a dual-use/misuse risk tier.
- [] Reassess whenever capability, access, model, provider, tool, or data changes.

2. Threat modeling

- [] Identify intentional misuse by external attackers, students, staff, insiders, compromised accounts, malicious prompt authors, vendors, and integrations.
- [] Model jailbreaks, direct/indirect prompt injection, context poisoning, exfiltration, credential theft, secret leakage, impersonation, social engineering, malware generation, fraud, harassment, nonconsensual imagery, and dangerous instructions.
- [] Identify harm pathways from generated content to real-world action.
- [] Identify risks created by multimodal inputs, files, voice, images, video, code execution, web retrieval, plugins, and external actions.
- [] Identify especially affected populations and institutional contexts.
- [] Record likelihood, impact, detectability, mitigation, residual risk, and owner.
- [] Define explicit stop/disable thresholds.

3. Capability and access controls

- [] Test relevant harmful or dual-use capabilities before deployment.
- [] Restrict access according to risk: public, authenticated, verified, institution-admin-approved, or sandbox-only.
- [] Require stronger identity verification for privileged or tool-enabled access.
- [] Apply rate limits, quotas, concurrency caps, abuse thresholds, and bot controls.
- [] Limit model contexts, file types, tokens, attachments, output formats, retrieval sources, and available tools by role and tenant.
- [] Use least privilege for every connected tool and API.
- [] Require user confirmation for external writes, scheduling, messages, data sharing, financial actions, SIS/LMS writes, or other consequential actions.
- [] Remove, gate, or sandbox capabilities whose residual misuse risk is unacceptable.

4. Defense in depth

- [] Enforce policy and authorization before calling the model.
- [] Use tenant-scoped, allowlisted retrieval sources.
- [] Separate untrusted content from system/developer instructions.
- [] Detect and resist direct and indirect prompt injection.
- [] Scan files for malware and unsafe content before ingestion.
- [] Redact secrets and unnecessary PII before model-provider calls.
- [] Apply input and output safety filters appropriate to the use case.
- [] Use sandboxed code execution with restricted network, filesystem, process, identity, and secret access.
- [] Validate tool parameters against schemas and allowlists.
- [] Generate action previews and require user confirmation.
- [] Create feature flags, kill switches, provider/model rollback, and tenant disable.
- [] Keep a manual fallback for high-value workflows.

5. Measure and monitor

- [] Maintain representative, approved evaluation sets for each use case.
- [] Test grounding, hallucination, citation validity, refusal quality, policy adherence, privacy leakage, safety, bias, accessibility, and usability.
- [] Run adversarial testing for jailbreaks, injection, exfiltration, dangerous instructions, fraud, impersonation, and tool misuse.
- [] Test cross-tenant isolation and source authorization.
- [] Test model/tool behavior after model, provider, prompt, policy, integration, or retrieval changes.
- [] Monitor blocked/allowed request patterns, abuse attempts, safety-report volume, override rate, false positives, false negatives, appeals, incidents, time-to-detection, and time-to-resolution.
- [] Detect model drift and provider behavior changes.
- [] Review evaluation and production metrics at defined risk-tier intervals.

6. Response, accountability, and transparency

- [] Maintain AI incident categories, severity levels, owners, and response timelines
- [] Preserve minimum necessary evidence under access, retention, and legal-hold rules
- [] Contain harm through account restriction, capability disablement, model rollback, tenant disablement, or provider escalation.
- [] Support user reporting of unsafe, harmful, inaccessible, inaccurate, biased, privacy-invasive, or policy-violating output.
- [] Give users understandable source, policy, limitation, and escalation labels.
- [] Maintain an appeal/correction mechanism for consequential enforcement.
- [] Notify institutions, users, providers, insurers, and regulators when required.
- [] Conduct root-cause analysis and track corrective actions to closure.
- [] Reassess the risk register and evaluation plan after every material incident.
- [] Publish appropriate aggregate transparency information without creating new abuse

Required artifact set

A control is not audit-ready until it produces evidence. Maintain:

AI Governance Charter and RACI
AI Acceptable Use Policy
AI Model/System Inventory
AI Vendor and Provider Assessment
AI Use-Case Dossier
AI Data-Flow Diagram
AI Misuse Threat Model
AI Impact Assessment
Risk-Tiering Decision
Evaluation Policy and Risk-Tier Test Standard
Evaluation Plan, Datasets, Results, and Sign-Offs
Red-Team/Adversarial Test Report
Accessibility and Fairness Test Evidence
Security, Privacy, and Tenant-Isolation Test Report
Tool/Agent Permission Map
Production Configuration and Feature-Flag Record
AI Incident Response Plan and Exercise Evidence
Incident Register and Corrective-Action Tracker
Model/Provider Change Log
User Transparency and Issue-Reporting Evidence
Risk Acceptance / Exception Register
Retirement and Offboarding Plan

Release gate

No AI feature should enter production until the accountable owner can answer “yes” to all of these:

- [] The intended use, prohibited use, and authority boundary are documented.
- [] A named business owner, technical owner, and escalation owner exist.
- [] The risk tier and AI 800-1 applicability are recorded.
- [] Data flows, retention, provider terms, and tenant isolation are approved.
- [] Relevant misuse, privacy, security, accessibility, quality, and grounding tests

- [] Launch-blocking thresholds are satisfied or a formally approved exception exists
- [] User-facing source, policy, limitation, and report controls are live.
- [] Tool permissions are least-privilege, previewable, and confirmation-gated.
- [] Monitoring, incident response, kill switch, and rollback have been tested.
- [] Customer/institution configuration, contract commitments, and support documentation
- [] Required audit evidence is stored, versioned, and retrievable.

The strongest governance posture is not claiming that AI is safe in the abstract. It is proving, feature by feature, that Semester has identified the relevant harms, tested the controls, limited access and authority, monitored behavior, and can rapidly stop or correct the system when evidence shows risk.



1. <https://airc.nist.gov/technical-reports/>
2. <https://www.nist.gov/news-events/news/2024/07/departments-commerce-announces-new-guidance-tools-270-days-following>
3. <https://pages.nist.gov/NIST-Tech-Pubs/DRAFT.html>